

**UNIVERSIDAD POLITÉCNICA
DE SAN LUIS POTOSÍ**

ACT. 07

**LAB: FILE PATH
TRAVERSAL SIMPLE CASE**

CNO IV: Seguridad Informática

Fabiola Calvillo Galván 182455
Mtro. Servando López Contreras
Otoño 2026

LABORATORIO: FILE PATH TRAVERSAL PORTSWIGGER WEB SECURITY ACADEMY

Introducción

Nombre del laboratorio: File Path Traversal Simple Case

Nivel del laboratorio: Apprentice

Tipo de explotación: Se trata de una vulneración Path Traversal (también llamada Directory Traversal o Traversal de Directorios) específicamente una variante de lectura arbitraria de archivos.

Objetivo del laboratorio

El objetivo de este laboratorio es poder leer un archivo que se encuentra completamente fuera del directorio determinado por la aplicación, es una “prueba de concepto” clásica, ya que es legible por cualquier usuario.

Lab: File path traversal, simple case



This lab contains a path traversal vulnerability in the display of product images.

To solve the lab, retrieve the contents of the `/etc/passwd` file.



Explicación técnica de la vulnerabilidad

La página nos muestra un catálogo en donde se presentan diferentes imágenes. Estas imágenes tienen un endpoint, que es donde se presenta la vulnerabilidad. El endpoint recibe el nombre del archivo a través de un parámetro controlado por el usuario y se utiliza directamente para construir la ruta del archivo que será leído en el sistema de archivos del servidor, sin aplicar ningún tipo de validación o normalización previa.

En condiciones normales, el endpoint recibe una solicitud como la siguiente:

GET /image?filename=218.png

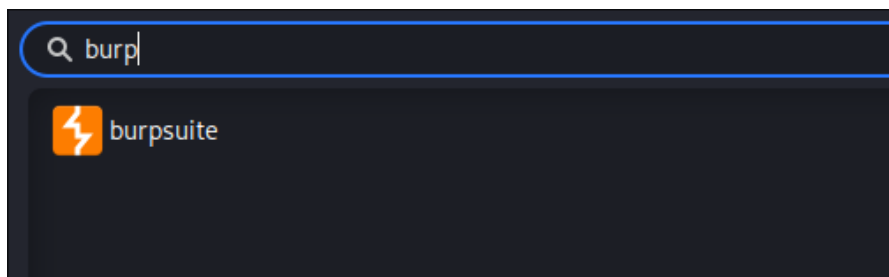
El problema surge por que ya que no cuenta con una validación, y la aplicación confía ciegamente en que el valor de **filename** corresponderá siempre a un nombre de archivo simple y legítimo dentro del directorio de imágenes

Explotación

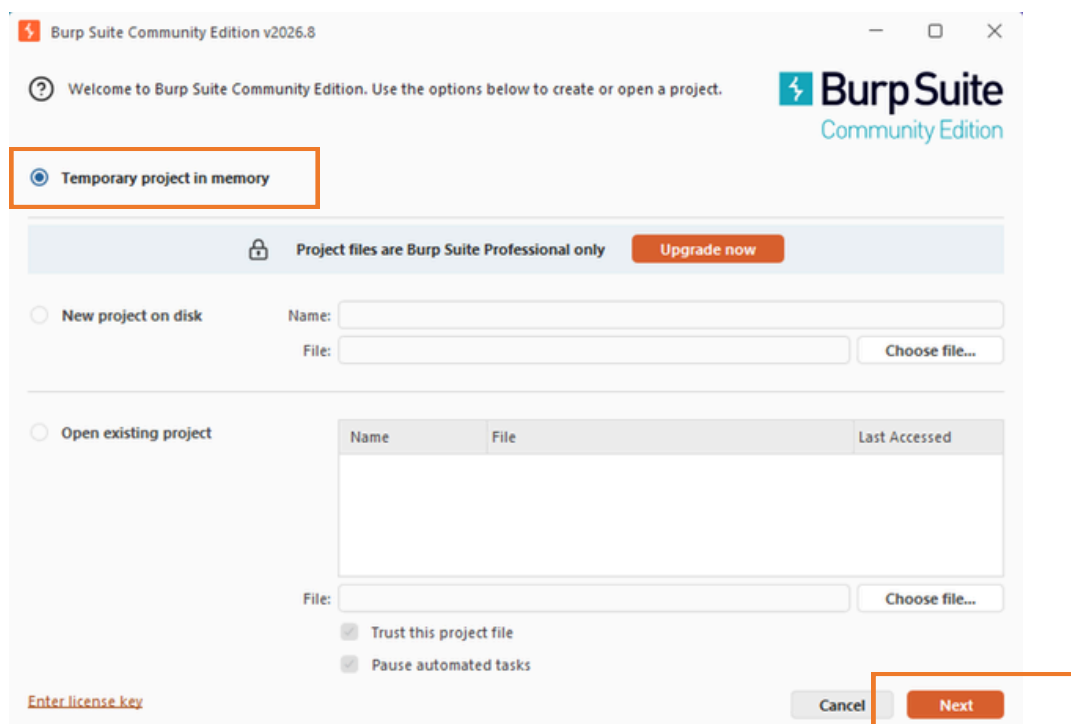
Dado que los sistemas operativos interpretan la secuencia ../ como una instrucción para retroceder un nivel de jerarquía de directorios, un atacante puede manipular fácilmente el parámetro **filename** para incluir múltiples secuencias de este tipo y así “escapar” del directorio, alcanzando la raíz del sistema de archivos y, desde ahí, navegar hacia cualquier otro directorio del servidor.

Procedimiento paso a paso

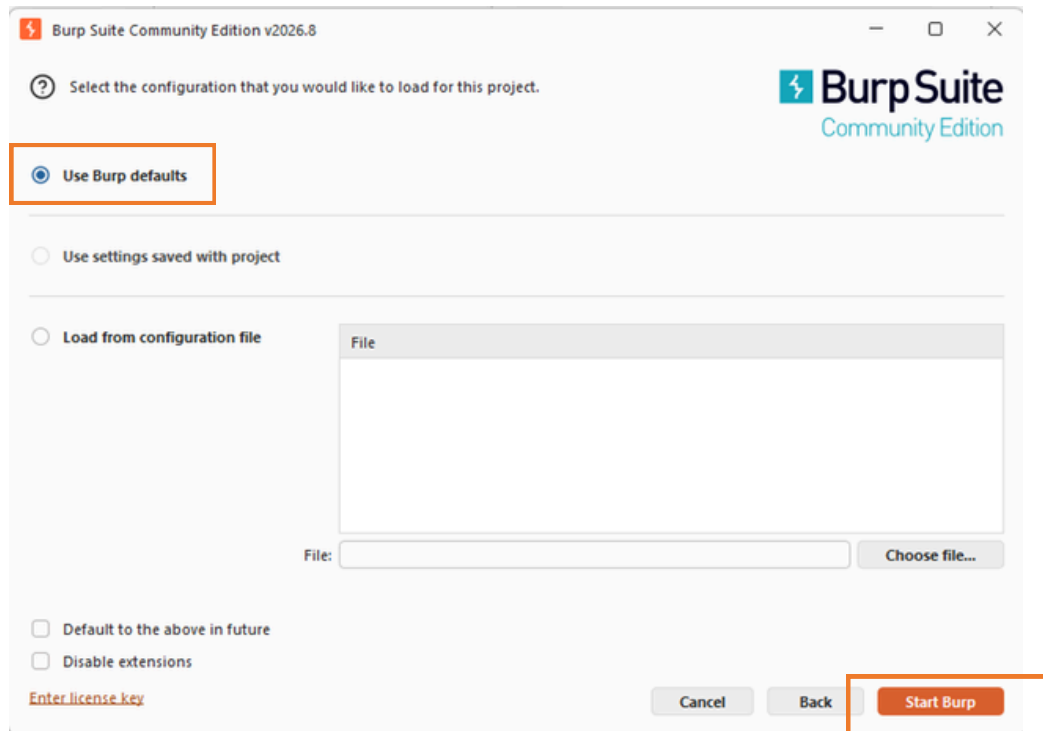
Como primer paso, tenemos que buscar el sistema BurpSuite, en este caso estamos utilizando el BurpSuite Community Edition. Damos clic e iniciamos el sistema.



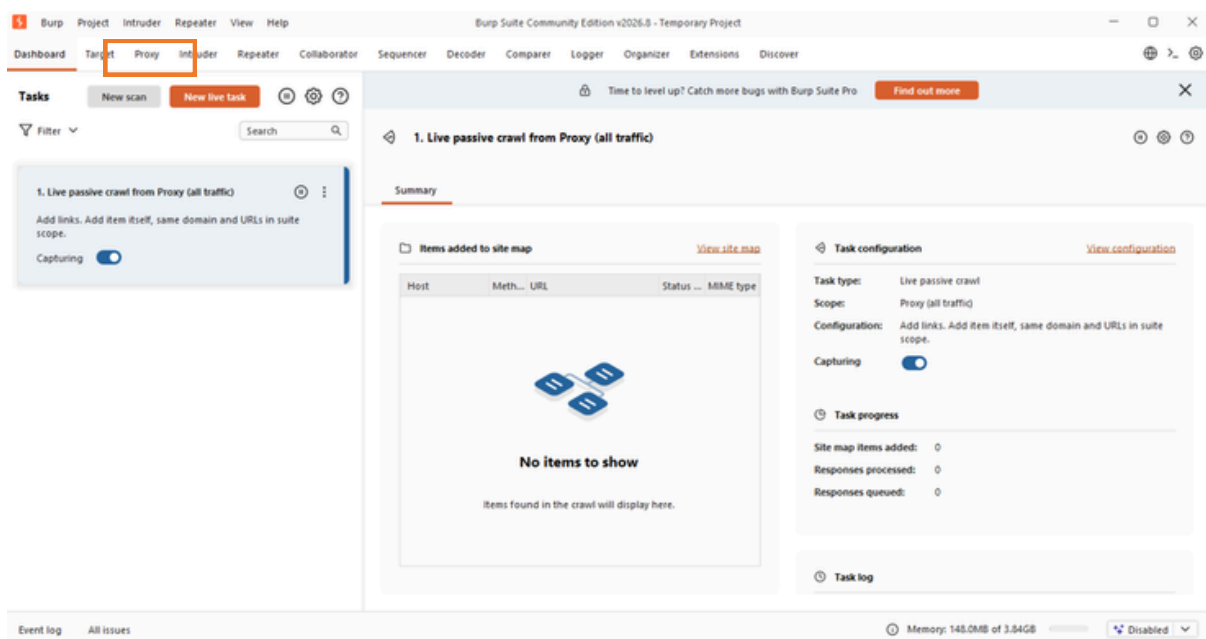
Una vez iniciado el sistema, se muestra en pantalla para poder inicializar un nuevo proyecto, en esta ocasión estaremos utilizando la opción de Proyecto temporal en memoria, damos siguiente.



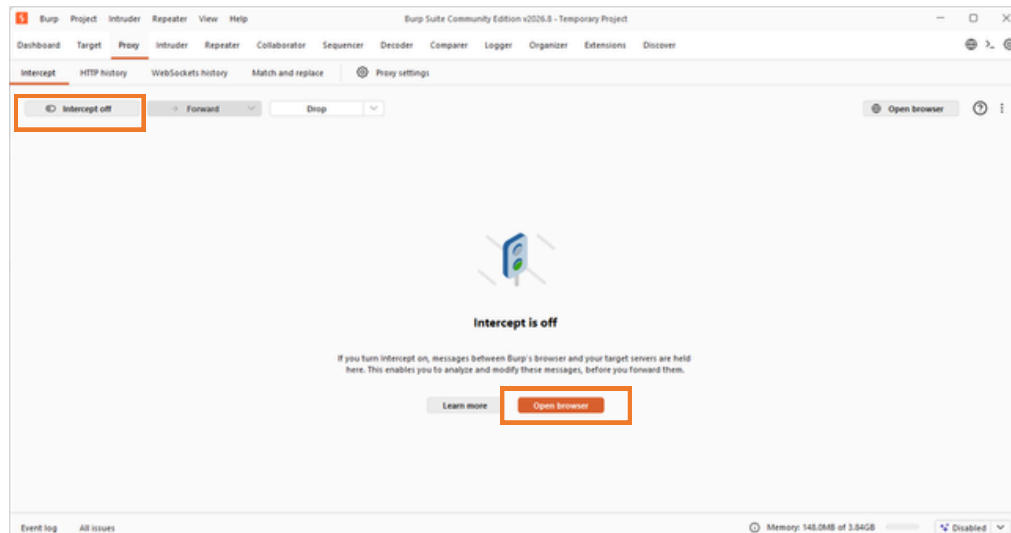
Continuamos y en la siguiente página se muestra la configuración con la que estaremos trabajando, dejaremos la configuración que maneja por default y damos clic en **Start Burp**.



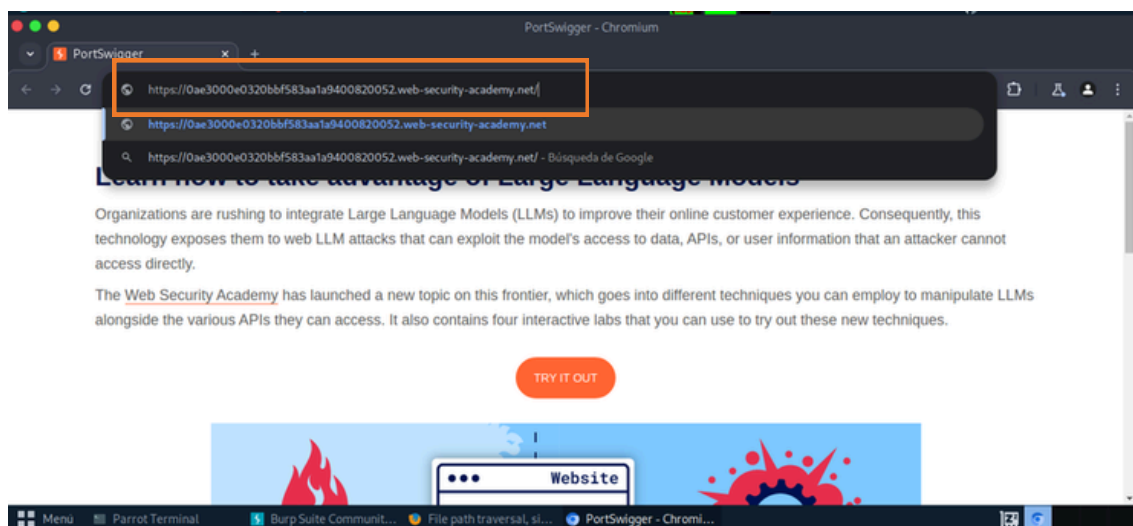
Después de haber ingresado, en la pestaña actual se muestra el dashboard que es la página principal, en este momento nosotros debemos de buscar el apartado de **proxy**, para ahora dar clic e irnos a esa pestaña.



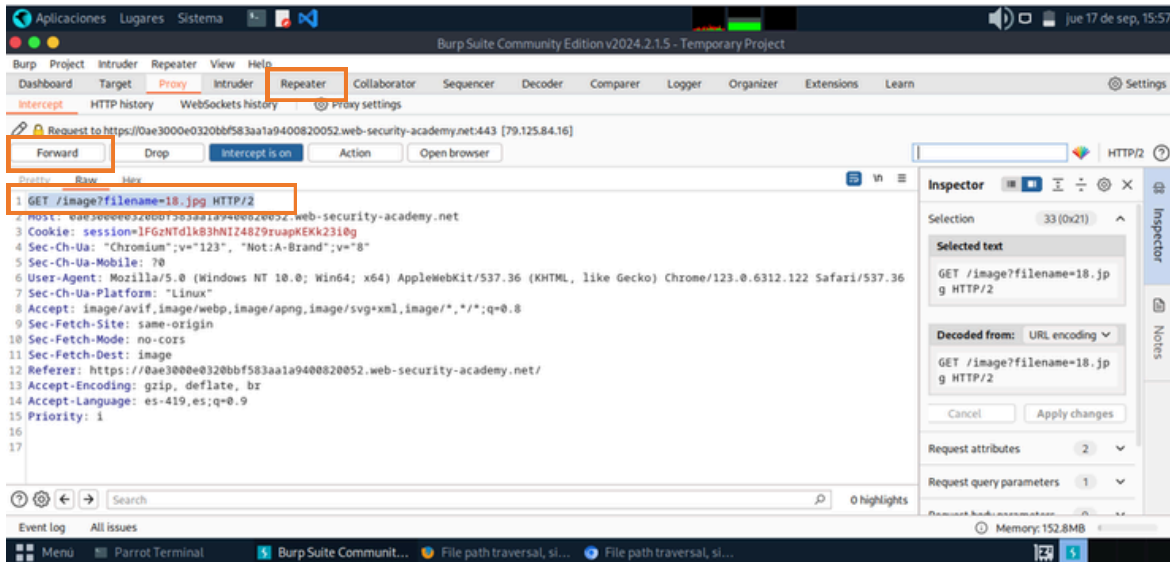
Ya estando en **Proxy**, podemos observar que hay un botón que dice **Intercept off**, debemos de dar clic ahí para encenderlo, también podemos observar que en medio de la pestaña aparece un botón en naranja que dice **Open Browser**, también debemos de dar clic en ese botón para poder abrir el navegador y poder iniciar nuestra práctica.



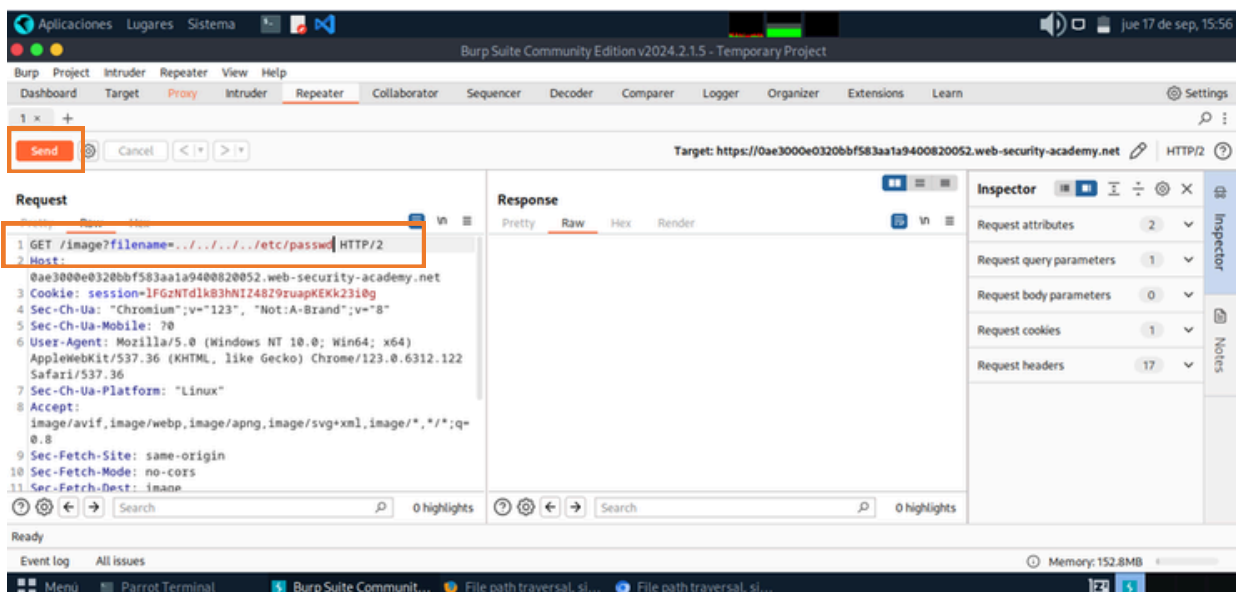
Ya dentro del navegador tenemos que ingresar el URL, que nos sale cuando accedimos al laboratorio.



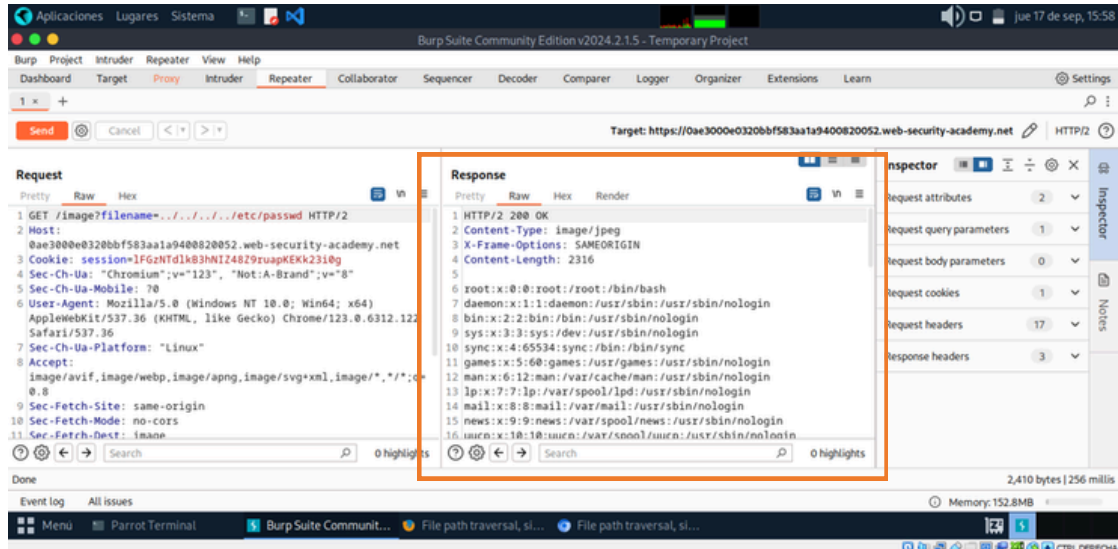
Una vez cargada la página debemos de dar clic en **Forward** para que se puedan cargar las diferentes acciones de la página, en cuanto nos salga un endpoint que diga **GET /image?filename=18.jpg HTTP/2**, seleccionamos esa instrucción y damos clic derecho, en donde se nos mostraran diferentes opciones, daremos clic en la opción de **Send to Repeater**, para después irnos a la pestaña de **Repeater**.



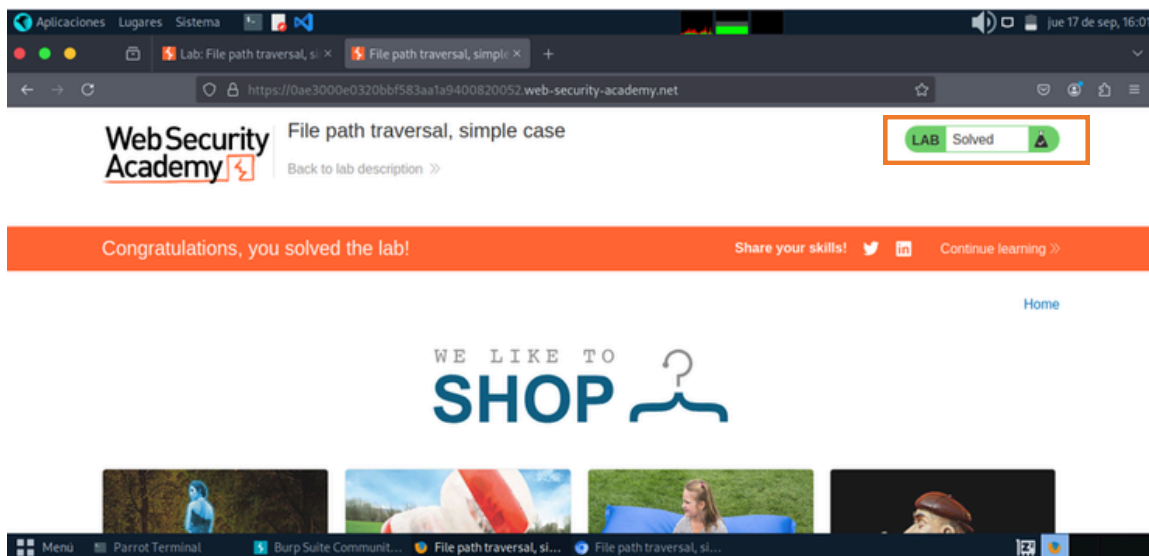
Una vez en la pestaña de **Repeater** debemos de modificar el endpoint, debemos de reemplazar el nombre del **filename** por lo siguiente: **../../../../etc/passwd** esto para poder movernos al directorio root y poder visualizar la información que contiene ese directorio, para eso debemos de dar clic en **Send**, para poder realizar esta acción.



Después de haber mandado la instrucción, en el apartado de **Response** se muestra el contenido del directorio.



Una vez que podamos observar esta información la práctica de este laboratorio está terminada, podemos comprobar que la completamos en la misma página donde estuvimos trabajando, en una esquina nos aparecer **LAB Solved**.



Explicación del Payload

Payload utilizado:

../../../etc/passwd

Desglose	Función
../	Cada ocurrencia indica al sistema operativo "sube un nivel en la jerarquía de directorios".
../../	Retrocede tres niveles desde el directorio base de imágenes hasta alcanzar la raíz del sistema de archivos (/).
etc/passwd	Una vez en la raíz, especifica la ruta relativa al archivo objetivo

Mitigación Recomendada

1. Validación mediante lista blanca (allow-list)

En lugar de aceptar cualquier nombre de archivo, validar la entrada contra una lista de archivos o patrones permitidos explícitamente. Esta es la mitigación más robusta, ya que no depende de detectar patrones maliciosos, sino de permitir únicamente lo que se sabe que es seguro.

2. Uso de indentificadores indirectos en lugar de nombres de archivo

Reemplazar el nombre de archivo real por un identificador (ID numérico o UUID) que se mapee internamente a la ruta del archivo en el servidor. De esta forma, el usuario nunca controla directamente ninguna porción de la ruta del sistema de archivos.